

Cloud Security Posture Management

What is Cloud Security Posture Management (CSPM)?

Cloud security posture management (CSPM) solutions automatically identify compliance risks and misconfiguration issues in cloud environments. CSPM tools work by continuously monitoring cloud environments for gaps in security policy enforcement. It helps organizations extend their cloud security strategy to multi-cloud and hybrid cloud environments.

CSPM technology is commonly deployed across Infrastructure as a Service (IaaS) cloud services. However, it can also reduce compliance risks and minimize configuration mistakes in Platform as a Service (PaaS) and Software as a Service (SaaS) cloud environments.

Why is CSPM Important?

Cloud systems are dynamic and enormously complex. Many cloud systems are exposed to public networks by default, and as organizations move more workloads and data to the cloud, security challenges mount.

Traditional security tools are not effective in cloud environments. The reason is that there is no perimeter to protect, manual security processes cannot cope with the number of assets and the speed at which they change, and visibility is limited due to the distributed nature of the cloud.

Key challenges of cloud security include:

- **Heterogeneous resources**—including containers, serverless functions, Kubernetes clusters, storage buckets, and dedicated cloud services or SaaS applications, many of which perform critical business functions.
- **Cybersecurity skills gap**—a global shortage in cybersecurity professionals means that new technologies are deployed faster than organizations can hire security experts to protect them.

- **Infrastructure as Code (IaC)**—this pattern allows infrastructure to be deployed and managed via machine-readable definitions. This creates the possibility of IaC templates with programming errors or malicious elements that can expose the environment to vulnerabilities.
- **Limited visibility**—in a complex and dynamic environment, such as a cloud with hundreds of thousands of instances and accounts, many of which are automated, it is extremely difficult to know what is running and who is doing what. Vulnerabilities may go unnoticed for prolonged periods, or even until a breach occurs.

CSPM addresses these challenges by achieving visibility over complex cloud environments, continuously monitoring cloud assets, and enabling detection and response to risks and vulnerabilities.

How Does CSPM Work?

CSPM tools automatically detect and remediate cloud misconfigurations. CSPM works by employing continuous monitoring and automation capabilities to detect and correct issues. It allows you to configure continuous compliance according to several standards, such as HIPAA and GDPR.

CSPM tools provide continuous, real-time infrastructure visualization and facilitate discovery, risk assessment, and classification of multi-cloud assets. CSPM protects against common misconfigurations, such as expired encryption keys, incorrect permissions, disabled logs, unencrypted data, and lack of security updates.

You can employ CSPM tools to perform custom automation that solves common problems in real-time. It can also help you secure continuous delivery for DevOps teams. However, CSPM capabilities vary between tools. Some CSPM tools can only catch issues related to a specific cloud service or environment, such as AWS or Azure, and automatic remediation capabilities are different for each tool.

Related content: [Read our guide to cloud security assessments \(coming soon\)](#)

CSPM vs CWPP

Cloud Workload Protection Platforms (CWPP) provide a workload-centric security solution for all types of workloads, including physical servers, virtual machines (VMs), containers, and serverless workloads. CWPP provides a single pane of glass for visibility and protection across on-premises and cloud environments.

CWPP makes it possible to identify vulnerabilities earlier in the development lifecycle, and can also detect exploits and active threats in live environments, providing improved context and investigation for incident responders.

Cloud Security Posture Management (CSPM) protects workloads “from the outside”, by monitoring the security configuration of the cloud platform control plane, while CWPP protects workloads “from the inside”, identifying how workloads themselves are configured.

In this sense, CWPP has a greater focus on application security, while CSPM can help ensure the cloud environment as a whole follows security and compliance best practices. Increasingly, organizations are using both CWPP and CSPM to holistically secure cloud environments.

In 2021, Gartner introduced a new solution category, called Cloud Native Application Protection Platform (CNAPP), which includes both CSPM and CWPP in a single platform.

Best Practices for Adopting CSPM Tools

The following best practices can help you adopt CSPM solutions more effectively:

- **Integrate CSPM with a Security Information and Event Management (SIEM)**—this gives administrators a single view of all activity across on-premise and cloud assets. This makes it easier to identify and fix misconfigured assets and other potential vulnerabilities in your cloud environment, and makes CSPM more accessible to the security operations center (SOC).
- **Integrate CSPM with other DevOps tools**—this is key to successful adoption of new cloud security solutions. Integrating with the existing toolset means SecOps, DevOps, and technology infrastructure teams can share the same reporting scheme and dashboards.
- **Use Internet Security Center (ISC) cloud benchmarks**—the ISC security benchmarks are an important goal for enterprises adopting CSPM. These benchmarks contain detailed best practices that ensure a cloud environment is secure. Use CSPM to ensure that your cloud environment gradually moves closer to ISC benchmark requirements.
- **Prioritize cloud security risks**—analyze risks in your environment and prioritize those that can have the greatest impact. CSPM can help you automatically fix low-priority issues and send alerts only when critical threats are detected. This approach prevents alert fatigue and allows cloud management teams to focus on issues that automation cannot solve.

Complementing CSPM with Bug Bounties and Pentesting

As organizations continue to expand their digital footprint, potential risks incurred by cloud-native businesses are growing and evolving like never before. HackerOne’s consolidated platform addresses the evergrowing compliance risks and misconfiguration issues in cloud environments by calling on a strong community of ethical hackers that bring unique expertise

to find vulnerabilities automated tools miss. With the vulnerability intelligence and built-in reporting HackerOne provides, organizations can track the progress instantly and harden their cloud security posture continuously over time.

There are two key HackerOne product offerings that can assist organizations looking to protect their cloud-based assets and increase the effectiveness of an existing CSPM tool:

- 1. [HackerOne Bounty](#) minimizes the risk of cyberattacks by inviting a deep pool of ethical hackers with varying backgrounds and skill sets to cover diverse cloud attack surfaces. Security teams can track bug bounty program performance in a centralized dashboard that shows them the greatest risks to their business. They can also benchmark their efforts against similar programs and integrate results with their existing bug tracking, mitigation, or CSPM tools through [a powerful API](#) to take fast, effective security actions.
- 2. [HackerOne Assessments](#) brings a creative, community-led approach to cloud pentesting while delivering more coverage, real-time results, and seamless remediation workflows. Our compliance-ready reports help organizations meet SOC 2 Type II, ISO 27001, HI HITRUST, FISMA, PCI, and other custom requirements. As part of the HackerOne Assessments, the [AWS-specific solutions](#) give visibility across AWS environments by tapping into the experience of background-checked, AWS-certified ethical hackers. The pentest results and vulnerability findings can also be seamlessly routed [from HackerOne to AWS Security Hub](#), or through HackerOne API endpoints.

Company	Knowledge	Resources
Leadership	Center	Blog
Careers	Application Security	Documentation
Partners	Penetration Testing	Leaderboard
Newsroom	Cloud Security	Partner Portal
Contact Us	Hacking	Resources
Contacted by a hacker?	Cybersecurity	
	Attacks	
	DevSecOps	

